LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	bpsdm.kemenhub.go.id
URL Lengkap	https://bpsdm.kemenhub.go.id/
Tanggal Audit	21 May 2026, 11:15:10 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	264.24 detik

SECURITY GRADE: F **SKOR: 13/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **bpsdm.kemenhub.go.id** telah dilakukan pada tanggal **21 May 2026, 11:15:10 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 57 pengecekan keamanan yang dilakukan, sistem mendapat grade **F** dengan skor **13/100**. Ditemukan total **33 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	1	Risiko tertinggi, harus segera diperbaiki
HIGH	4	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	7	Risiko sedang, jadwalkan perbaikan
LOW	21	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Directory: /.env.old	CRITICAL
Deskripsi:	Path /.env.old accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #2: Strict-Transport-Security	HIGH
Deskripsi:	Memaksa browser selalu menggunakan HTTPS
Rekomendasi:	Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

Temuan #3: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #4: File: /.htaccess	HIGH
Deskripsi:	EXPOSED! File konfigurasi Apache exposed — bisa berisi rewrite rules & auth config (HTTP 200, 603 bytes)
Rekomendasi:	Konfigurasi web server agar tidak melayani file dot-files

Temuan #5: Cookie: XSRF-TOKEN (session)	HIGH
Deskripsi:	Cookie 'XSRF-TOKEN' memiliki 1 masalah: Missing Secure flag
Rekomendasi:	Set flag: Secure pada cookie 'XSRF-TOKEN'

Temuan #6: X-Frame-Options	MEDIUM
Deskripsi:	Mencegah clickjacking via iframe
Rekomendasi:	Tambahkan header: X-Frame-Options: DENY atau SAMEORIGIN

Temuan #7: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #8: Cookie: TS01a2049c	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #9: Cookie: XSRF-TOKEN	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #10: Cookie: bpsdm_session	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #11: File: /admin/	MEDIUM
Deskripsi:	EXPOSED! Admin panel terdeteksi — perlu verifikasi apakah dilindungi autentikasi (HTTP 200, 7228 bytes)
Rekomendasi:	Pastikan admin panel dilindungi autentikasi kuat + IP allowlist

Temuan #12: Clickjacking: /	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: X-Frame-Options, CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #13: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #14: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #15: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #16: Info Leak: Email Address [/]	LOW
Deskripsi:	Email address ditemukan di source code — bisa digunakan untuk phishing/spam. Value (masked): sekr****o.id
Rekomendasi:	Jangan hardcode email di HTML. Gunakan form kontak atau obfuscation.

Temuan #17: Directory: /admin	LOW
Deskripsi:	Path /admin accessible (HTTP 200, 7228 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #18: Directory: /admin/	LOW
Deskripsi:	Path /admin/ accessible (HTTP 200, 7228 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #19: Directory: /.env.bak	LOW
Deskripsi:	Path /.env.bak accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #20: Directory: /.env.save	LOW
Deskripsi:	Path /.env.save accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #21: Directory: /access.log	LOW
Deskripsi:	Path /access.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #22: Directory: /error.log	LOW
Deskripsi:	Path /error.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #23: Directory: /app.log	LOW
Deskripsi:	Path /app.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #24: Directory: /application.log	LOW
Deskripsi:	Path /application.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #25: Directory: /debug.log	LOW
Deskripsi:	Path /debug.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #26: Directory: /.htaccess	LOW
Deskripsi:	Path /.htaccess accessible (HTTP 200, 603 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #27: Directory: /nginx.conf	LOW
Deskripsi:	Path /nginx.conf accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #28: Directory: /wp-config.php.bak	LOW
Deskripsi:	Path /wp-config.php.bak accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #29: Directory: /httpd.conf	LOW
Deskripsi:	Path /httpd.conf accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #30: Directory: /server.log	LOW
Deskripsi:	Path /server.log accessible (HTTP 200, 246 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #31: Directory: /sitemap.xml	LOW
Deskripsi:	Path /sitemap.xml accessible (HTTP 200, 1482 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #32: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 74 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #33: security.txt (missing)	LOW
Deskripsi:	security.txt tidak ditemukan — best practice adalah menyediakan file ini agar security researcher tahu cara melaporkan kerentanan
Rekomendasi:	Buat file /.well-known/security.txt sesuai RFC 9116. Minimal berisi Contact: dan Expires: fields.

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **3** | Failed: **10** | Total: **13**

Check	Severity
Strict-Transport-Security	HIGH
Content-Security-Policy	HIGH
X-Frame-Options	MEDIUM
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Cookie: TS01a2049c	MEDIUM
Cookie: XSRF-TOKEN	MEDIUM
Cookie: bpsdm_session	MEDIUM

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **33** | Failed: **2** | Total: **35**

Check	Severity
File: /.htaccess	HIGH
File: /admin/	MEDIUM

Module 4 — CMS Detection

Passed: **1** | Failed: **0** | Total: **1**

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **1** | Failed: **0** | Total: **1**

Module 10 — Port Reconnaissance

Passed: **2** | Failed: **0** | Total: **2**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **bpsdm.kemenhub.go.id** memiliki **1 kerentanan CRITICAL** dan **4 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [CRITICAL] Directory: /.env.old
Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

2. [HIGH] Strict-Transport-Security
Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

3. [HIGH] Content-Security-Policy
Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

4. [HIGH] File: /.htaccess
Konfigurasi web server agar tidak melayani file dot-files

5. [HIGH] Cookie: XSRF-TOKEN (session)
Set flag: Secure pada cookie 'XSRF-TOKEN'

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026